

PLAN DE RESPUESTA A INCIDENTES

y

SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

NIST SP 800-61 Rev. 2 · ISO/IEC 27001:2022 · Fase 3

Servidor crítico Debian Linux – 4Geeks Academy

Responsable del documento	Bryan Calderón – Analista de Ciberseguridad
Clasificación	CONFIDENCIAL – USO INTERNO
Versión	1.0 – Final
Fecha de elaboración	22 de mayo de 2026
Organización	4Geeks Academy – Entorno de laboratorio educativo
Marcos normativos	NIST SP 800-61 Rev. 2 · ISO/IEC 27001:2022 · ENS
Servidor analizado	Debian GNU/Linux – IP 192.168.1.131

PARTE A – PLAN DE RESPUESTA A INCIDENTES (NIST SP 800-61 Rev. 2)

1. Introducción y Propósito

El presente Plan de Respuesta a Incidentes (PRI) define los procedimientos, roles y responsabilidades que la organización debe seguir ante la ocurrencia de incidentes de ciberseguridad en el servidor Debian Linux del entorno de laboratorio de 4Geeks Academy. El plan ha sido desarrollado siguiendo las directrices del NIST SP 800-61 Rev. 2 ('Computer Security Incident Handling Guide') y está fundamentado en los incidentes reales documentados en las Fases 1 y 2 de este proyecto.

Los incidentes analizados —un servidor con múltiples servicios inseguros expuestos y una instalación WordPress comprometida mediante RCE— proporcionan la base práctica sobre la que se construyen los procedimientos de este plan, enriquecida con los controles técnicos implementados en mayo de 2026.

2. Alcance

Este plan aplica a todos los incidentes de seguridad que afecten a los sistemas de información del laboratorio de 4Geeks Academy, incluyendo:

- Servidores de aplicaciones web (Apache, WordPress, servicios SSH).
- Bases de datos (MariaDB/MySQL).
- Infraestructura de red del entorno de laboratorio (192.168.1.0/24).
- Cualquier activo de información clasificado como crítico o importante.

3. Clasificación de Incidentes

Nivel	Severidad	Criterios	Ejemplo del laboratorio
P1	CRÍTICO	RCE confirmado, acceso root obtenido, exfiltración de datos en curso.	Plugin malicioso con shell www-data. Acceso no autorizado a wp-admin.
P2	ALTO	Servicio crítico comprometido, credenciales expuestas, acceso no autorizado a BD.	wp-config.php con credenciales en texto plano. FTP expuesto sin cifrado.
P3	MEDIO	Vulnerabilidad confirmada sin explotación activa, misconfiguration detectada.	SSH sin hardening. Directory listing habilitado. Tema WordPress desactualizado.
P4	BAJO	Eventos informativos, anomalías sin impacto confirmado.	Errores de red en logs. Servicio CUPS activo sin explotación.

4. Ciclo de Respuesta a Incidentes (NIST SP 800-61)

4.1 Fase 1 – Preparación

La preparación es la fase más importante del ciclo. Los controles técnicos implementados en mayo de 2026 (UFW, HTTPS, backups, retención de logs) forman parte de esta fase y elevan significativamente la postura de seguridad del servidor.

4.1.1 Inventario de activos críticos

Activo	Tipo	Criticidad	Responsable
Servidor Debian – 192.168.1.131	Servidor virtual	CRÍTICA	Administrador de sistemas – 4Geeks Academy
WordPress + Apache 2.4.67	Aplicación web	CRÍTICA	Desarrollador web / Analista de seguridad
Base de datos MariaDB	BBDD	CRÍTICA	DBA / Administrador de sistemas
Firewall UFW	Control de acceso	ALTA	Administrador de sistemas
Red de laboratorio (192.168.1.0/24)	Infraestructura red	ALTA	Administrador de red

4.2 Fase 2 – Detección y Análisis

4.2.1 Indicadores de Compromiso (IoC) identificados en el incidente

Indicador de Compromiso (IoC)	Tipo	Fuente de detección
Plugin desconocido 'Security Tool' activo	Artefacto malicioso	Revisión manual de plugins WordPress
wp-config.php con DB_PASSWORD='123456'	Credencial débil	Auditoría de configuración
xmlrpc.php accesible sin autenticación	Servicio expuesto	WPScan, Nmap
pam_unix(sudo:auth): conversation failed	Log de autenticación	/var/log/auth.log, journalctl
unix_chkpwd: password check failed (debian)	Intento de acceso fallido	journalctl grep failed
Múltiples crashes del sistema (jul 2024 – may 2026)	Inestabilidad del sistema	Comando last, journalctl

4.3 Fase 3 – Contención, Erradicación y Recuperación

Artefacto / Vulnerabilidad	Acción de erradicación ejecutada
----------------------------	----------------------------------

Plugin malicioso shell.php	rm -rf /var/www/html/wp-content/plugins/shell/ → curl → 404 ✓
Servicio vsftpd (FTP) expuesto	systemctl stop vsftpd && systemctl disable vsftpd → Puerto 21 cerrado ✓
Servicio CUPS innecesario	systemctl stop cups && systemctl disable cups ✓
XML-RPC expuesto	.htaccess: Deny from all para xmlrpc.php → curl → 404 ✓
Contraseña BD débil (123456)	ALTER USER wordpressuser IDENTIFIED BY 'Wordpress1234' ✓
SSH sin hardening	PermitRootLogin no + MaxAuthTries 3 + LoginGraceTime 30 ✓
Sistema sin actualizar	apt update && apt upgrade -y – Parches de seguridad aplicados ✓
Sin firewall perimetral	UFW activo: deny incoming, allow 22/80/443 – 22 mayo 2026 ✓
HTTP sin cifrado	Apache HTTPS + certificado SSL RSA 2048 + HSTS – 22 mayo 2026 ✓

4.4 Fase 4 – Actividad Post-Incidente

4.4.1 Lecciones aprendidas

Lo que falló	Mejora aplicada
Logs sin revisión durante ~22 meses.	Retención journald 90 días + logrotate Apache 90 ciclos. Implementado 22/05/2026.
Sin firewall entre Internet y la red interna.	UFW activo: deny-all incoming, allow 22/80/443. Implementado 22/05/2026.
HTTP sin cifrado – credenciales en tránsito expuestas.	HTTPS con certificado SSL RSA 2048 + HSTS 1 año. Implementado 22/05/2026.
Sin política de backups – riesgo de pérdida total de datos.	Script mysqldump + tar.gz con cron diario a las 02:00. Implementado 22/05/2026.

PARTE B – SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (ISO/IEC 27001:2022)

5. Introducción al SGSI

El Sistema de Gestión de Seguridad de la Información (SGSI) descrito en este documento se desarrolla conforme a los requisitos de la norma ISO/IEC 27001:2022, aplicados al entorno de laboratorio de 4Geeks Academy. El SGSI establece el marco organizativo, técnico y procedimental para proteger la confidencialidad, integridad y disponibilidad de la información gestionada por la organización.

Durante el mes de mayo de 2026 se ejecutó una fase de implementación técnica que elevó cuatro controles del estado PENDIENTE a IMPLEMENTADO, completando el núcleo técnico del SGSI para este entorno de laboratorio.

6. Análisis y Evaluación de Riesgos (Cláusula 6.1 ISO 27001)

#	Vulnerabilidad	Severidad	Vector	CWE
1	FTP sin cifrado – exposición de credenciales	CRÍTICA	Red – Puerto 21 vsftpd	CWE-200 – Exposición de info. sensible
2	RCE via plugin malicioso en WordPress	CRÍTICA	Red – wp-admin upload plugin	CWE-434 – Carga de archivos peligrosos
3	Credenciales BD en texto plano	CRÍTICA	Local – wp-config.php DB_PASSWORD='123456'	CWE-256 – Almacenamiento sin protección
4	HTTP sin cifrado – datos en tránsito expuestos	ALTA	Red – Puerto 80 Apache sin TLS	CWE-319 – Transmisión en texto claro
5	Sin firewall – tráfico sin filtrar	ALTA	Red – Sin política deny-all	CWE-16 – Configuración incorrecta
6	Sin backups – riesgo de pérdida de datos	ALTA	Operacional – Sin política de respaldo	CWE-653 – Insuficiente separación de privilegios
7	Logs sin retención – trazabilidad perdida	MEDIA	Operacional – journald sin retención definida	CWE-778 – Registro de seguridad insuficiente

7. Controles Implementados — Fase Final (Mayo 2026)

El 22 de mayo de 2026 se completó la implementación técnica de cuatro controles críticos del Anexo A de ISO/IEC 27001:2022 que se encontraban en estado PENDIENTE. A continuación se documenta cada control con su evidencia técnica.

7.1 Control A.8.20 — Seguridad en Redes (UFW Firewall)

Objetivo: Gestionar y controlar el tráfico de red hacia y desde la organización para proteger los sistemas de accesos no autorizados.

Se implementó Uncomplicated Firewall (UFW) en el servidor Debian 192.168.1.131. La política por defecto se configuró para denegar todo el tráfico entrante y permitir únicamente los puertos 22 (SSH), 80 (HTTP) y 443 (HTTPS).

Comando ejecutado	Resultado obtenido
ufw default deny incoming	Default incoming policy changed to 'deny'
ufw default allow outgoing	Default outgoing policy changed to 'allow'
ufw allow 22/tcp	Rules updated / Rules updated (v6)
ufw allow 80/tcp	Rules updated / Rules updated (v6)
ufw allow 443/tcp	Rules updated / Rules updated (v6)
ufw enable	Firewall is active and enabled on system startup

Verificación — ufw status verbose:

Servicio	Puerto	Acción	Origen IPv4	Origen IPv6
SSH	22/tcp	ALLOW IN	Anywhere	Anywhere (v6)
HTTP	80/tcp	ALLOW IN	Anywhere	Anywhere (v6)
HTTPS	443/tcp	ALLOW IN	Anywhere	Anywhere (v6)

Criterio de cumplimiento	Evidencia	Estado
Firewall activo y persistente en arranque	enabled on system startup	✓ CUMPLIDO
Política deny por defecto (incoming)	deny (incoming)	✓ CUMPLIDO
Solo puertos necesarios habilitados	22, 80, 443 únicamente	✓ CUMPLIDO
Soporte IPv4 e IPv6	Reglas duplicadas v6	✓ CUMPLIDO

7.2 Control A.8.24 — Uso de Criptografía (HTTPS + HSTS)

Objetivo: Asegurar el uso apropiado y efectivo de criptografía para proteger la confidencialidad, autenticidad e integridad de la información en tránsito.

Se habilitó Apache 2.4.67 en Debian para operar bajo HTTPS en el puerto 443, utilizando un certificado SSL autofirmado RSA 2048-bit con validez de 365 días. Se activó el encabezado HTTP Strict Transport Security (HSTS) para forzar conexiones cifradas durante 1 año.

Componente	Valor / Ruta	Descripción
Versión Apache	2.4.67 (Debian)	Servidor web principal
Módulo SSL	mod_ssl (a2enmod ssl)	Habilita soporte TLS/SSL
Módulo Headers	mod_headers (a2enmod headers)	Permite HSTS y cabeceras de seguridad
Certificado	/etc/apache2/ssl/apache.crt	Certificado público autofirmado (1261 bytes)
Llave Privada	/etc/apache2/ssl/apache.key	Clave RSA 2048-bit (1704 bytes)

Parámetros del certificado SSL:

Campo	Valor
Country (C)	CR (Costa Rica)
State (ST)	SanJose
Organization (O)	4Geeks Academy
Org. Unit (OU)	CyberSec – Bootcamp de Ciberseguridad
Common Name (CN)	192.168.1.131
Vigencia	365 días desde 22-05-2026
Algoritmo	RSA 2048-bit

Verificación — curl -k https://192.168.1.131 -I:

Header HTTP	Valor
HTTP Status	HTTP/1.1 200 OK
Servidor	Apache/2.4.67 (Debian)
HSTS	Strict-Transport-Security: max-age=31536000
Content-Length	10701 bytes

7.3 Control A.8.13 — Respaldo de Información (Backup Automatizado)

Objetivo: Mantener y probar regularmente copias de seguridad de la información, software e imágenes de sistemas para garantizar la disponibilidad ante incidentes.

Se desarrolló un script de respaldo automatizado en Bash que realiza copias de seguridad diarias de las bases de datos MySQL y los archivos del servidor web Apache. Los respaldos se almacenan comprimidos en formato .gz con marca de tiempo y se eliminan automáticamente los archivos con más de 90 días de antigüedad.

Ruta	Descripción
/backup/scripts/backup.sh	Script principal de respaldo
/backup/data/	Directorio de almacenamiento de respaldos
/var/log/backup.log	Registro de ejecuciones del backup
/etc/cron.d/backup-iso27001	Programación de ejecución automática

Programación Cron — ejecución diaria automática:

```
| 0 2 * * * root /backup/scripts/backup.sh
```

Evidencia de ejecución (22/05/2026):

Archivo generado	Tamaño	Fecha	Tipo
db_20260522_102633.sql.gz	796 KB	22 May 2026 10:26	MySQL Dump
web_20260522_102633.tar.gz	32 MB	22 May 2026 10:26	Web Files

Criterio de cumplimiento	Evidencia	Estado
Backup de base de datos funcional	db_*.sql.gz – 796 KB	✓ CUMPLIDO
Backup de archivos web funcional	web_*.tar.gz – 32 MB	✓ CUMPLIDO
Purga automática backups > 90 días	find -mtime +90 -delete	✓ CUMPLIDO
Ejecución automática diaria (02:00 AM)	cron.d/backup-iso27001	✓ CUMPLIDO
Log de auditoría generado	/var/log/backup.log	✓ CUMPLIDO

7.4 Control A.8.15 — Retención de Registros (Logs 90 Días)

Objetivo: Producir, almacenar, proteger y analizar registros de actividades, excepciones, fallas y otros eventos relevantes para la detección de incidentes y cumplimiento normativo.

Se configuraron dos mecanismos de retención de logs: (1) systemd-journald para los logs del sistema con retención de 90 días y límite de 500 MB, y (2) logrotate para los logs de Apache con rotación diaria y conservación de 90 copias comprimidas.

Configuración journald — /etc/systemd/journald.conf:

Parámetro	Valor configurado	Descripción
MaxRetentionSec	90day	Retención máxima de logs del sistema
SystemMaxUse	500M	Límite de espacio en disco para journals

Configuración logrotate — /etc/logrotate.d/apache2-iso27001:

Parámetro	Valor	Efecto
rotate	90	Conserva 90 archivos de log rotados
daily	diario	Rotación diaria de los logs
compress + delaycompress	gzip	Compresión con delay para el archivo más reciente
postrotate systemctl reload apache2	automático	Recarga Apache tras cada rotación

Criterio de cumplimiento	Evidencia	Estado
Retención journald 90 días configurada	MaxRetentionSec=90day	✓ CUMPLIDO
Límite de almacenamiento definido	SystemMaxUse=500M	✓ CUMPLIDO
Integridad de journals verificada	journalctl --verify PASS	✓ CUMPLIDO
logrotate Apache 90 rotaciones diarias	rotate 90 + daily	✓ CUMPLIDO
Compresión de logs históricos	compress + delaycompress	✓ CUMPLIDO

8. Controles de Seguridad — Declaración de Aplicabilidad (SoA) Actualizada

Estado actualizado al 22 de mayo de 2026, tras la implementación técnica de los controles A.8.20, A.8.24, A.8.13 y A.8.15:

Control	Descripción	Aplicable	Estado
A.5.1	Políticas de seguridad de la información	SÍ	☑ IMPLEMENTADO
A.5.29	Gestión de incidentes de seguridad	SÍ	☑ IMPLEMENTADO
A.8.3	Gestión de accesos privilegiados	SÍ	☑ IMPLEMENTADO
A.8.5	Autenticación segura	SÍ	🔒 PARCIAL – SSH hardened, 2FA pendiente
A.8.8	Gestión de vulnerabilidades técnicas	SÍ	🔒 PARCIAL – apt upgrade realizado
A.8.13	Backup y recuperación de información	SÍ	☑ IMPLEMENTADO – 22/05/2026
A.8.15	Registro y monitorización	SÍ	☑ IMPLEMENTADO – 22/05/2026
A.8.20	Seguridad en redes	SÍ	☑ IMPLEMENTADO – 22/05/2026
A.8.24	Uso de criptografía – HTTPS TLS	SÍ	☑ IMPLEMENTADO – 22/05/2026
A.8.32	Gestión de cambios	SÍ	⌚ PENDIENTE – trabajo a futuro

9. Resumen Global de Cumplimiento

Estado de implementación al 22 de mayo de 2026:

Control	Nombre ISO 27001	Fecha implementación	Estado
A.8.20	Network Firewall – UFW	22-05-2026	✔ IMPLEMENTADO
A.8.24	Uso de Criptografía – HTTPS	22-05-2026	✔ IMPLEMENTADO
A.8.13	Respaldo de Información	22-05-2026	✔ IMPLEMENTADO
A.8.15	Registro de Actividades	22-05-2026	✔ IMPLEMENTADO
A.8.3	Gestión accesos privilegiados	Mayo 2026	✔ IMPLEMENTADO
A.5.29	Gestión de incidentes	Mayo 2026	✔ IMPLEMENTADO
A.8.5	Autenticación segura	–	🔒 PARCIAL
A.8.8	Gestión de vulnerabilidades	–	🔒 PARCIAL
A.8.32	Gestión de cambios	–	⌚ PENDIENTE

Indicador	Valor
Controles IMPLEMENTADOS	6 de 9 (67%)
Controles PARCIALES	2 de 9 (22%)
Controles PENDIENTES	1 de 9 (11%) – A.8.32 Gestión de cambios
Fecha de estado	22 de mayo de 2026

10. Conclusiones

Durante el mes de mayo de 2026 se completó la implementación técnica del núcleo de controles del SGSI para el servidor Debian del laboratorio de 4Geeks Academy. Los cuatro controles implementados —UFW, HTTPS, backups automatizados y retención de logs— representan las medidas de mayor impacto en la reducción de la superficie de ataque y en la capacidad de respuesta ante incidentes.

El estado de cumplimiento pasó de un 33% inicial (3 controles implementados) a un 67% (6 controles implementados), con dos controles adicionales en estado parcial. El único control pendiente —A.8.32 Gestión de cambios— requiere el diseño de un proceso organizativo y plantillas de documentación, trabajo que se contempla como siguiente paso en la madurez del SGSI.

La implementación de estos controles en un entorno de laboratorio educativo demuestra que la seguridad técnica básica no requiere herramientas costosas ni infraestructura compleja: UFW, OpenSSL, Bash y systemd son suficientes para alcanzar un nivel de cumplimiento significativo con ISO/IEC 27001:2022.

11. Referencias Normativas

- ISO/IEC 27001:2022 – Information Security Management Systems. International Organization for Standardization.
- NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide. NIST, agosto 2012.
- ISO/IEC 27005:2022 – Information Security Risk Management.
- ENS – Esquema Nacional de Seguridad. Real Decreto 311/2022, BOE España.
- RGPD – Reglamento General de Protección de Datos. Reglamento (UE) 2016/679.
- CIS Controls v8. Center for Internet Security. <https://www.cisecurity.org/controls/>